

Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ
ИТМО
ITMO University

Практическая работа №10

По дисциплине Информационная безопасность

Тема работы Анализ сетевого трафика

Обучающийся Сакулин Иван Михайлович

Факультет Факультет прикладной информатики

Группа К3321

Направление подготовки 11.03.02 Инфокоммуникационные технологии и
системы связи

Образовательная программа Программирование в инфокоммуникацион-
ных системах

Обучающийся

(дата)

(подпись)

Сакулин И.М.

(Ф.И.О.)

Руководитель

(дата)

(подпись)

Пикуль А.С.

(Ф.И.О.)

СОДЕРЖАНИЕ

Стр.

ВВЕДЕНИЕ	3
1 ХОД РАБОТЫ.....	4
1.1 Обзор трафика в Wireshark	4
1.1.1 Общая картина	4
1.1.2 Нормальный фон	5
1.1.3 Фильтры отображения	6
1.2 Ручной поиск подозрительной активности	7
1.2.1 Доставка.....	7
1.2.2 Управление.....	7
1.2.3 Вывод данных	8
1.3 Автоматическое обнаружение в Suricata	10
1.3.1 Стандартные правила	10
1.3.2 Собственное правило	13
1.4 Сравнение.....	14
ЗАКЛЮЧЕНИЕ	16
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ	17
ПРИЛОЖЕНИЕ А Фильтры отображения в Wireshark	18

ВВЕДЕНИЕ

В работе рассматривается анализ сетевого трафика с целью выявления признаков атак и подозрительной активности. Для исследования используются два подхода: ручной анализ дампа в Wireshark и автоматическое обнаружение событий системой обнаружения вторжений Suricata.

Цель работы — научиться исследовать сетевой трафик и обнаруживать в нём признаки атак двумя способами: вручную в Wireshark и автоматически системой обнаружения вторжений Suricata.

Для достижения поставленной цели необходимо решить следующие задачи:

- изучить общую структуру сетевого трафика в Wireshark и определить основные протоколы, узлы и соединения;
- исследовать трафик с помощью фильтров Wireshark и найти не менее трёх подозрительных признаков;
- классифицировать обнаруженные признаки по этапам атаки;
- выполнить офлайн-анализ того же PCAP в Suricata по стандартным правилам;
- создать собственное правило Suricata под один из найденных признаков и проверить его срабатывание;
- сравнить результаты ручного и автоматического анализа, а также рассмотреть ложные срабатывания и пропуски;
- сформулировать выводы и меры защиты сетевого трафика.

В качестве исходных данных использован дмп сетевого трафика PCAP с сайта *Malware-Traffic-Analysis*. Файл трафика взят со страницы с разбором образца от 03.02.2023 [1]. Анализ выполнялся в Wireshark и Suricata в офлайн-режиме.

1 ХОД РАБОТЫ

1.1 Обзор трафика в Wireshark

1.1.1 Общая картина

В дампе преобладает TCP-трафик: на него приходится 95.2% всех пакетов, при этом 20.3% составляет TLS, 3.3% — data и 0.5% — HTTP. Доля UDP составляет 3.2%, из которых 1.6% приходится на DNS, ещё 1.5% занимает ARP. Таким образом, основную часть взаимодействия составляют TCP-соединения, в том числе зашифрованные, а DNS и ARP занимают значительно меньшую долю.

Сводная информация по иерархии протоколов приведена на рисунке 1. Количественный состав соединений по участникам и типам сетевого взаимодействия представлен на рисунке 2. Активные конечные точки и объёмы их трафика показаны на рисунке 3.

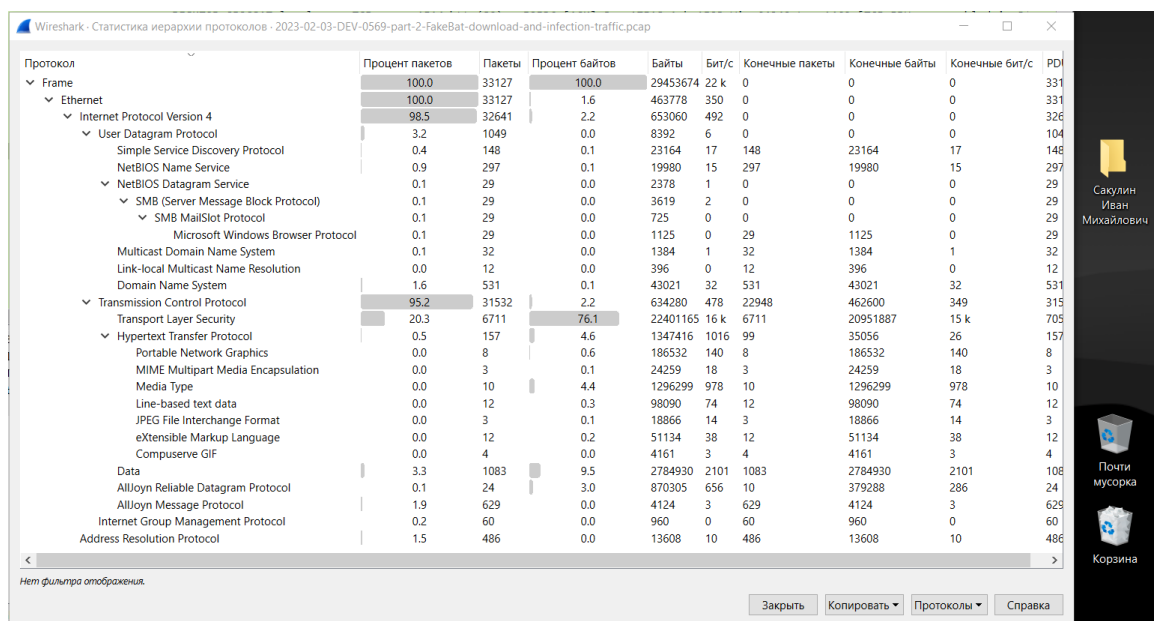


Рисунок 1 — Иерархия протоколов в Wireshark

Адрес А	Адрес В	Пакеты	Байт	ИД потока	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Отн. время начала
10.2.3.101	10.2.3.1	822	97 кБ	1	600	57 кБ	222	40 кБ	2.466138
10.2.3.101	10.2.3.255	35	8 кБ	24	35	8 кБ	0	0 байты	100.297615
10.2.3.101	13.107.18.254	23	8 кБ	62	10	1 кБ	13	7 кБ	2643.760559
10.2.3.101	13.107.42.12	376	213 кБ	28	155	61 кБ	221	152 кБ	199.561417
10.2.3.101	13.107.136.254	23	8 кБ	61	10	1 кБ	13	7 кБ	2643.760174
10.2.3.101	13.107.246.254	25	9 кБ	64	11	1 кБ	14	8 кБ	2643.767931
10.2.3.101	20.10.31.115	182	36 кБ	9	88	12 кБ	94	24 кБ	19.269648
10.2.3.101	20.42.65.85	23	9 кБ	97	10	3 кБ	13	6 кБ	3542.344710
10.2.3.101	20.42.72.131	396	195 кБ	27	195	130 кБ	201	65 кБ	197.709048
10.2.3.101	20.42.73.24	52	21 кБ	98	25	12 кБ	27	10 кБ	3819.960906
10.2.3.101	20.42.73.26	22	8 кБ	106	9	3 кБ	13	6 кБ	9548.383192
10.2.3.101	20.42.73.27	23	8 кБ	59	10	3 кБ	13	6 кБ	2348.264322
10.2.3.101	20.44.10.122	86	27 кБ	40	37	9 кБ	49	17 кБ	252.703532
10.2.3.101	20.44.239.154	25	7 кБ	103	11	2 кБ	14	5 кБ	6952.111139
10.2.3.101	20.72.205.209	25	7 кБ	105	11	2 кБ	14	5 кБ	8753.747393
10.2.3.101	20.81.51.95	84	43 кБ	13	36	10 кБ	48	33 кБ	21.204012
10.2.3.101	20.81.52.156	25	12 кБ	60	11	3 кБ	14	9 кБ	2643.173670

Рисунок 2 — Диалоги сетевого трафика в Wireshark

Адрес	Порт	Пакеты	Байты	Пакетов отправлено	Байтов отправлено	Пакетов получено	Байтов получено
51.104.15.252	443	41	21 кБ	23	7 кБ	18	15 кБ
52.96.69.98	443	34	11 кБ	19	7 кБ	15	3 кБ
52.96.103.18	443	26	9 кБ	14	7 кБ	12	2 кБ
52.96.181.66	443	53	24 кБ	29	15 кБ	24	9 кБ
52.96.182.130	443	48	16 кБ	26	11 кБ	22	5 кБ
52.109.20.80	443	47	22 кБ	26	16 кБ	21	7 кБ
52.113.194.132	443	60	28 кБ	36	25 кБ	24	3 кБ
52.137.108.250	443	41	24 кБ	25	15 кБ	16	8 кБ
52.152.108.96	443	53	23 кБ	28	6 кБ	25	17 кБ
52.153.155.231	443	31	10 кБ	16	8 кБ	15	2 кБ
52.183.220.149	443	46	14 кБ	28	6 кБ	18	8 кБ
52.184.206.73	443	77	33 кБ	42	21 кБ	35	12 кБ
52.184.215.140	443	104	48 кБ	58	36 кБ	46	12 кБ
52.254.114.65	443	149	103 кБ	92	62 кБ	57	41 кБ
62.204.41.175	44271	2 107	1 МБ	1 230	73 кБ	877	1 МБ
62.204.41.176	80	232	273 кБ	192	271 кБ	40	2 кБ
67.27.98.254	80	11	1 кБ	5	607 байты	6	617 байты
72.21.81.240	80	14	2 кБ	7	962 байты	7	888 байты

Рисунок 3 — Конечные точки сетевого взаимодействия

В таблице Conversations были рассмотрены взаимодействующие узлы, объёмы трафика и длительность соединений. Все основные диалоги связаны с внутренним узлом 10.2.3.101 и внешними адресами. Зафиксировано 215 диалогов по TCP, 287 по UDP, 108 по IPv4 и 6 по Ethernet.

В таблице Endpoints среди соединений на нестандартных портах выделяются 62.204.41.175:44271 и 194.87.216.194:9955. Дальнейший анализ этих соединений выполнялся отдельно.

1.1.2 Нормальный фон

Основной фон трафика состоит преимущественно из TCP-соединений, при этом значительная часть приходится на TLS. Также присутствуют UDP-

соединения, в том числе DNS, и небольшой объём ARP. Основное взаимодействие происходит между внутренним узлом сети 10.2.3.101 и внешними адресами. По количеству соединений трафик достаточно разнообразный: зафиксировано большое число TCP и UDP диалогов.

На первый взгляд выделяется большое количество коротких соединений к внешним узлам через TCP/443, что соответствует HTTPS/TLS-трафику. Однако помимо этого присутствуют два объёмных соединения с нестандартными портами.

1.1.3 Фильтры отображения

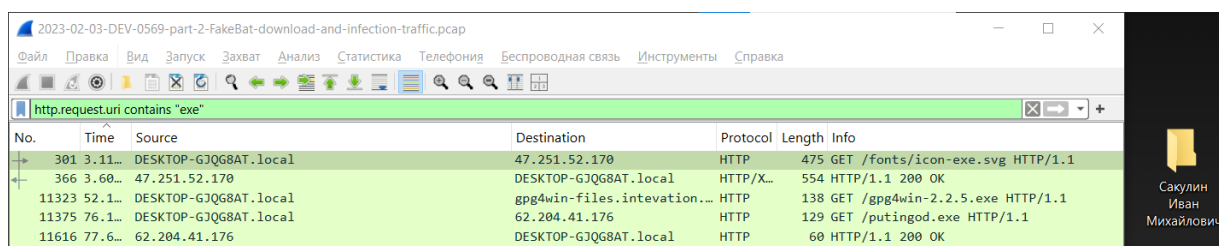
Были опробованы различные фильтры в Wireshark. Примеры их применения приведены в приложении А на рисунках А.1–А.8.

- `ip.addr == 10.2.3.101` — трафик конкретного адреса (рисунок А.1);
- `tcp.port == 80` или `http` — веб-трафик (рисунок А.2);
- `dns` — DNS-запросы (рисунок А.3);
- `tcp.flags.syn == 1 && tcp.flags.ack == 0` — только SYN-пакеты, поиск сканирования (рисунок А.4);
- `http.request` — HTTP-запросы (рисунок А.5);
- `ftp || telnet` — протоколы, передающие данные в открытом виде; результатов нет (рисунок А.6);
- `tcp.flags.reset == 1` — RST-пакеты, большое количество которых может указывать на проблемы с соединениями или сканирование (рисунок А.7);
- `http.request.method == "POST"` — запросы с передачей данных серверу (рисунок А.8).

1.2 Ручной поиск подозрительной активности

1.2.1 Доставка

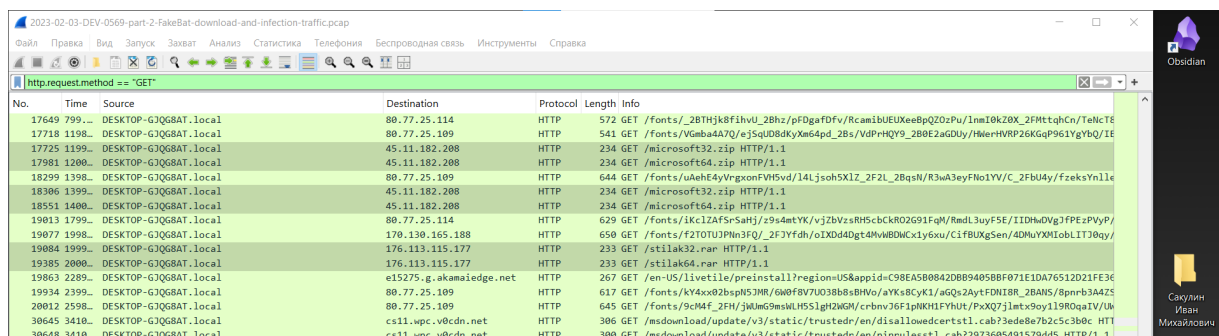
Первый найденный признак: скачивание исполняемых exe-файлов. Записи были обнаружены фильтром `http.request.uri contains "exe"`. Для скачивания `putingod.exe` произошло обращение к прямому IP-адресу без доменного имени `62.204.41.176`. Это нетипично для обычного скачивания установщиков (рисунок 4).



No.	Time	Source	Destination	Protocol	Length	Info
301	3.11...	DESKTOP-GJQG8AT.local	47.251.52.170	HTTP	475	GET /fonts/icon-exe.svg HTTP/1.1
366	3.60...	47.251.52.170	DESKTOP-GJQG8AT.local	HTTP/X..	554	HTTP/1.1 200 OK
11323	52.1...	DESKTOP-GJQG8AT.local	gpg4win-files.intevation...	HTTP	138	GET /gpg4win-2.2.5.exe HTTP/1.1
11375	76.1...	DESKTOP-GJQG8AT.local	62.204.41.176	HTTP	129	GET /putingod.exe HTTP/1.1
11616	77.6...	62.204.41.176	DESKTOP-GJQG8AT.local	HTTP	60	HTTP/1.1 200 OK

Рисунок 4 — Загрузка `putingod.exe` с адреса `62.204.41.176`

При просмотре результатов фильтра `http.request.method == "GET"` были обнаружены подозрительные архивы (рисунок 5). Это могут быть исполняемые файлы вредоносного ПО, поэтому относим событие к этапу доставки.



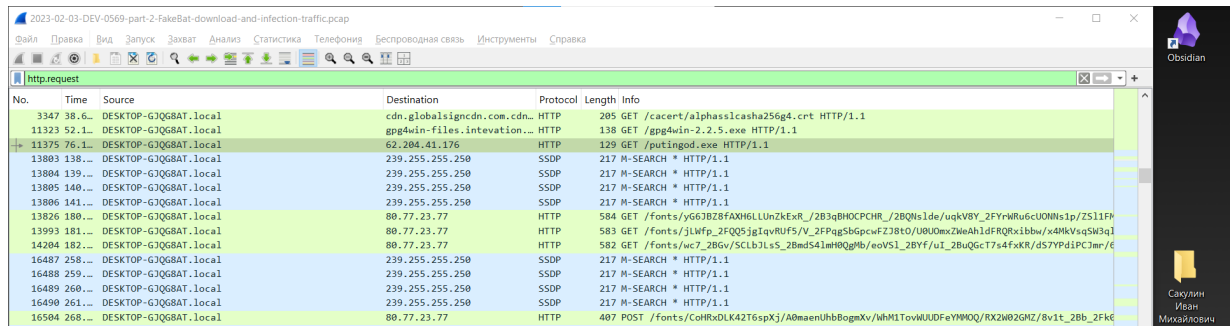
No.	Time	Source	Destination	Protocol	Length	Info
17649	799...	DESKTOP-GJQG8AT.local	80.77.25.114	HTTP	572	GET /fonts/_2BThjk8fihvU_2Bhz/pFDgaFDfv/RcamibUEUXeeBpQZozPu/1nmI0kZ0X_2FmTtqhCn/TelicT6
17718	1198...	DESKTOP-GJQG8AT.local	80.77.25.109	HTTP	541	GET /fonts/VGmba4A7Q/ej5qU08dKxm64pd_2Bs/VdPrHQY9_2B0E2agDuy/HwerHVRP26GqP961YgVbQ/IE
17725	1199...	DESKTOP-GJQG8AT.local	45.11.182.208	HTTP	234	GET /microsfot32.zip HTTP/1.1
17981	1200...	DESKTOP-GJQG8AT.local	45.11.182.208	HTTP	234	GET /microsfot64.zip HTTP/1.1
18299	1398...	DESKTOP-GJQG8AT.local	80.77.25.109	HTTP	644	GET /fonts/uAehE4yVrgxonFVH5vd/14Ljsob5X1Z_2F2L_2BqsN/R3wa3eyFlo1YV/C_2FbU4y/fzeKsYn1le
18306	1399...	DESKTOP-GJQG8AT.local	45.11.182.208	HTTP	234	GET /microsfot32.zip HTTP/1.1
18551	1400...	DESKTOP-GJQG8AT.local	45.11.182.208	HTTP	234	GET /microsfot64.zip HTTP/1.1
19013	1799...	DESKTOP-GJQG8AT.local	80.77.25.114	HTTP	629	GET /fonts/IKcl24F5r5ahH/c54deYK/vjZbVzaRH5cckR02G91Fq/RndL3uyF5E/IIDHwDVg7FPePvPyj/
19077	1998...	DESKTOP-GJQG8AT.local	170.130.165.188	HTTP	650	GET /fonts/f210TUJPlw3FQ/_2FjYfdh/oIXDd4Dgt4MvM80NcX1y6xu/CiFBUXgSen/ADHwYXMIobLITJ8qy/
19084	1999...	DESKTOP-GJQG8AT.local	176.113.115.177	HTTP	233	GET /stilak32.rar HTTP/1.1
19385	2000...	DESKTOP-GJQG8AT.local	176.113.115.177	HTTP	233	GET /stilak64.rar HTTP/1.1
19863	2289...	DESKTOP-GJQG8AT.local	e15275.g.akamaiedge.net	HTTP	267	GET /en-US/livestyle/preinstall?region=US&appid=C98EA5B08420BB9405BBF071E1DA76512D21FE3E
19934	2399...	DESKTOP-GJQG8AT.local	80.77.25.109	HTTP	617	GET /fonts/kY4xx02bspN5JMR/6W0F8V7U03Bb8aBHV/aYksBcyK1/aGQs2AytFDNI8R_2BAN5/8pmrb3AAZS
20012	2598...	DESKTOP-GJQG8AT.local	80.77.25.109	HTTP	645	GET /fonts/9cM4f_2FH/jWlM69msWlH551gH2MGH/crbnvJ6F1pNKH1FYHut/PxXQ7jlmx9oy119RQaIV/UH
30645	3410...	DESKTOP-GJQG8AT.local	cs11.wpc.v0cdn.net	HTTP	306	GET /msdownload/update/v3/static/trusted/en/disallowedcertst1.cab?3ede8e7b2c5c3b0c HT
30648	3410...	DESKTOP-GJQG8AT.local	cs11.wpc.v0cdn.net	HTTP	300	GET /msdownload/update/v3/static/trusted/en/pinrulesst1.cab?72973685491579dd5 HTTP/1.1

Рисунок 5 — Подозрительные архивы в HTTP GET-запросах

1.2.2 Управление

Были просмотрены все `http.request` (рисунок 6). Наиболее интересными стали запросы после скачивания `putingod.exe`. Были замечены многочис-

ленные запросы вида `/fonts/[base64].[bak|dot|csv]`; после фильтрации были получены основные адреса: 80.77.23.77, 80.77.25.109, 80.77.25.114, 170.130.165.188 (рисунок 7). Это очень нетипично для скачивания шрифтов и может быть отнесено к этапу управления.



No.	Time	Source	Destination	Protocol	Length	Info
3347	38.6...	DESKTOP-GJQGBAT.local	cdn.globalsigncdn.com.cdn...	HTTP	205	GET /cacert/alphasslcache256g4.crt HTTP/1.1
11323	52.1...	DESKTOP-GJQGBAT.local	gpg4win-files.intevation...	HTTP	138	GET /gpg4win-2.2.5.exe HTTP/1.1
11375	76.1...	DESKTOP-GJQGBAT.local	62.204.41.176	HTTP	129	GET /putingod.exe HTTP/1.1
13803	138...	DESKTOP-GJQGBAT.local	239.255.255.250	SSDP	217	M-SEARCH * HTTP/1.1
13804	139...	DESKTOP-GJQGBAT.local	239.255.255.250	SSDP	217	M-SEARCH * HTTP/1.1
13805	140...	DESKTOP-GJQGBAT.local	239.255.255.250	SSDP	217	M-SEARCH * HTTP/1.1
13806	141...	DESKTOP-GJQGBAT.local	239.255.255.250	SSDP	217	M-SEARCH * HTTP/1.1
13826	180...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	584	GET /fonts/yG63B28fAXH6LLUnZkExR/_2B3qBHOCPCHR/_2BQNs1de/uqkV8Y_2FYrWRu6CUONMs1p/Z511F...
13993	181...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	583	GET /fonts/jLWfp_2FQ05jg1qvRUF5/V_2FPag5b6pcwFZ38t0/U0U0mxZMeAh1dFRQRxi1bbw/x4MkVsq5M3q1...
14204	182...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	582	GET /fonts/wc7_2B6v/SClBjLs5_2BndS41mh0QgHb/eovS1_2BYf/u1_2BuQ6cT7s4fxKR/d57YPd1PC3m7/E...
16487	258...	DESKTOP-GJQGBAT.local	239.255.255.250	SSDP	217	M-SEARCH * HTTP/1.1
16489	259...	DESKTOP-GJQGBAT.local	239.255.255.250	SSDP	217	M-SEARCH * HTTP/1.1
16490	260...	DESKTOP-GJQGBAT.local	239.255.255.250	SSDP	217	M-SEARCH * HTTP/1.1
16490	261...	DESKTOP-GJQGBAT.local	239.255.255.250	SSDP	217	M-SEARCH * HTTP/1.1
16504	268...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	407	POST /fonts/CoHrxDLK42T6spXj/A0maenUhbBogXv/NhM1TovMuUDeYMMQ/RX2W02GMZ/8v1t_2Bb_2FkE...

Рисунок 6 — HTTP-запросы в исследуемом трафике

No.	Time	Source	Destination	Protocol	Length	Info
550	4.66...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP/X...	707	HTTP/1.1 200 OK
13826	180...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	584	GET /fonts/yG63B28fAXH6LLUnZkExR/_2B3qBHOCPCHR/_2BQNs1de/uqkV8Y_2FYrWRu6CUONMs1p/Z511F...
13993	181...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	584	GET /fonts/jLWfp_2FQ05jg1qvRUF5/V_2FPag5b6pcwFZ38t0/U0U0mxZMeAh1dFRQRxi1bbw/x4MkVsq5M3q1...
14202	182...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	466	HTTP/1.1 200 OK (text/html)
14204	182...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	582	GET /fonts/wc7_2B6v/SClBjLs5_2BndS41mh0QgHb/eovS1_2BYf/u1_2BuQ6cT7s4fxKR/d57YPd1PC3m7/E...
14207	182...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	895	HTTP/1.1 200 OK (text/html)
16504	268...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	407	POST /fonts/CoHrxDLK42T6spXj/A0maenUhbBogXv/NhM1TovMuUDeYMMQ/RX2W02GMZ/8v1t_2Bb_2FkE...
16514	269...	DESKTOP-GJQGBAT.local	80.77.23.77	HTTP	261	HTTP/1.1 200 OK (text/html)
17649	799...	DESKTOP-GJQGBAT.local	80.77.25.114	HTTP	572	GET /fonts/_2B1HjK8fihvU_2Bhz/pFDgaFDFv/Rcam1BUeUXeeBpQZ0zPu/1nmI8kZ0X_2FmthqCn/TelHcT...
17651	799...	DESKTOP-GJQGBAT.local	80.77.25.114	HTTP	524	HTTP/1.1 404 Not Found (text/html)
17718	1198...	DESKTOP-GJQGBAT.local	80.77.25.109	HTTP	541	GET /fonts/V0mba4A7Q/e35qUD8DkyXm64pd_2Bs/VdPrHQY9_2B0E2aGDJy/HmerHVRP26KGaP961ygyQJ/IE...
17720	1198...	DESKTOP-GJQGBAT.local	80.77.25.109	HTTP	524	HTTP/1.1 200 OK (text/html)
18299	1398...	DESKTOP-GJQGBAT.local	80.77.25.109	HTTP	644	GET /fonts/uAehE4yVrgxonFVH5vd/14Ljs0h5K1Z_2F2L_2Bqsl/R3WA3eyFNo1YV/C_2FBu4y/fzeksYn1le...
18301	1398...	DESKTOP-GJQGBAT.local	80.77.25.109	HTTP	524	HTTP/1.1 200 OK (text/html)
19013	1799...	DESKTOP-GJQGBAT.local	80.77.25.114	HTTP	629	GET /fonts/iKc1ZAF5rSaHj/z9s4mtYK/vjZbVzsRH5cbckR02G91FqH/RmdL3uyF5E/IIDHuOvg3fPzePyvP/...
19015	1800...	DESKTOP-GJQGBAT.local	80.77.25.114	HTTP	782	HTTP/1.1 404 Not Found (text/html)
19077	1998...	DESKTOP-GJQGBAT.local	170.130.165.188	HTTP	650	GET /fonts/f2T0TUJPMn3FQ/_2FYfYdh/oIXDd4Dgt4MwBDMCk1y6u/C1fBUXgSen/4DMuYXMIob1T38qy/...
19079	1998...	DESKTOP-GJQGBAT.local	170.130.165.188	HTTP	507	HTTP/1.1 200 OK (text/html)
19742	2011...	DESKTOP-GJQGBAT.local	170.130.165.188	HTTP	1063	POST /fonts/ES9abCyn3BH7rGgz6eALoP/uGzhwF25Xp86VPB/FxFuEuorQL098u/L1_2BhwQW42cm6p3T/5...
19744	2012...	DESKTOP-GJQGBAT.local	170.130.165.188	HTTP	261	HTTP/1.1 200 OK (text/html)
19934	2399...	DESKTOP-GJQGBAT.local	80.77.25.109	HTTP	617	GET /fonts/kY4xx02b5pN53MR/6W0F8V7U038b8sBHVo/aYKsRCyK1/aGQs2AytFDNI8R_2BANs/8pnrB3A4Z5...
19936	2400...	DESKTOP-GJQGBAT.local	80.77.25.109	HTTP	443	HTTP/1.1 200 OK (text/html)

Рисунок 7 — Подозрительные запросы вида `/fonts/[base64].[bak|dot|csv]`

1.2.3 Вывод данных

Была проведена проверка подозрительного сокета `ip.addr == 62.204.41.175 && tcp.port == 44271` (рисунок 8). Такой трафик на нестандартном порту после скачивания `putingod.exe` весьма подозрителен.

2023-02-03-DEV-0569-part-2-fakeBat-download-and-infection-traffic.pcap

ip.addr == 62.204.41.175 && tcp.port == 44271

No.	Time	Source	Destination	Protocol	Length	Info
11718	95.6..	DESKTOP-GJQGBAT.local	62.204.41.175	TCP	1514	50571 → 44271 [ACK] Seq=28164 Ack=6558 Win=63299 Len=1460
11719	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=17944 Win=64240 Len=0
11720	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=19404 Win=64240 Len=0
11721	95.6..	DESKTOP-GJQGBAT.local	62.204.41.175	TCP	1514	50571 → 44271 [ACK] Seq=29624 Ack=6558 Win=63299 Len=1460
11722	95.6..	DESKTOP-GJQGBAT.local	62.204.41.175	TCP	1514	50571 → 44271 [ACK] Seq=31084 Ack=6558 Win=63299 Len=1460
11723	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=20864 Win=64240 Len=0
11724	95.6..	DESKTOP-GJQGBAT.local	62.204.41.175	TCP	1514	50571 → 44271 [ACK] Seq=32544 Ack=6558 Win=63299 Len=1460
11725	95.6..	DESKTOP-GJQGBAT.local	62.204.41.175	TCP	1514	50571 → 44271 [ACK] Seq=34004 Ack=6558 Win=63299 Len=1460
11726	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=22324 Win=64240 Len=0
11727	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=23784 Win=64240 Len=0
11728	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=25244 Win=64240 Len=0
11729	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=26704 Win=64240 Len=0
11730	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=28164 Win=64240 Len=0
11731	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=29624 Win=64240 Len=0
11732	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=31084 Win=64240 Len=0
11733	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=32544 Win=64240 Len=0
11734	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=34004 Win=64240 Len=0
11735	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=35464 Win=64240 Len=0
11736	95.6..	DESKTOP-GJQGBAT.local	62.204.41.175	TCP	1514	50571 → 44271 [ACK] Seq=35464 Ack=6558 Win=63299 Len=1460
11737	95.6..	DESKTOP-GJQGBAT.local	62.204.41.175	TCP	1514	50571 → 44271 [ACK] Seq=36924 Ack=6558 Win=63299 Len=1460
11738	95.6..	DESKTOP-GJQGBAT.local	62.204.41.175	TCP	1514	50571 → 44271 [ACK] Seq=38384 Ack=6558 Win=63299 Len=1460
11739	95.6..	DESKTOP-GJQGBAT.local	62.204.41.175	TCP	1514	50571 → 44271 [ACK] Seq=39844 Ack=6558 Win=63299 Len=1460
11740	95.6..	62.204.41.175	DESKTOP-GJQGBAT.local	TCP	54	44271 → 50571 [ACK] Seq=6558 Ack=36924 Win=64240 Len=0

Рисунок 8 — Соединение 10.2.3.101 с 62.204.41.175:44271

Аналогичная картина для ip.addr == 194.87.216.194 && tcp.port == 9955 (рисунок 9); это произошло очень скоро после скачивания microsoft64.zip.

2023-02-03-DEV-0569-part-2-fakeBat-download-and-infection-traffic.pcap

ip.addr == 194.87.216.194 && tcp.port == 9955

No.	Time	Source	Destination	Protocol	Length	Info
18242	1202..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	66	50639 → alljoyn-stm(9955) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
18243	1202..	194.87.216.194	DESKTOP-GJQGBAT.local	TCP	58	alljoyn-stm(9955) → 50639 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
18244	1202..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	54	50639 → alljoyn-stm(9955) [ACK] Seq=1 Ack=1 Win=64240 Len=0
18245	1202..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	110	50639 → alljoyn-stm(9955) [PSH, ACK] Seq=1 Ack=1 Win=64240 Len=56
18246	1202..	194.87.216.194	DESKTOP-GJQGBAT.local	TCP	54	alljoyn-stm(9955) → 50639 [ACK] Seq=1 Ack=57 Win=64240 Len=0
18247	1202..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	66	50639 → alljoyn-stm(9955) [PSH, ACK] Seq=57 Ack=1 Win=64240 Len=12 [TCP PDU reassembly
18248	1202..	194.87.216.194	DESKTOP-GJQGBAT.local	TCP	54	alljoyn-stm(9955) → 50639 [ACK] Seq=1 Ack=69 Win=64240 Len=0
18253	1227..	194.87.216.194	DESKTOP-GJQGBAT.local	ALLJOYN	55	CONNECT-initial byte
18254	1227..	DESKTOP-GJQGBAT.local	194.87.216.194	ALLJOYN	55	CONNECT-initial byte
18257	1257..	194.87.216.194	DESKTOP-GJQGBAT.local	ALLJOYN	55	CONNECT-initial byte
18258	1257..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	54	50639 → alljoyn-stm(9955) [ACK] Seq=69 Ack=3 Win=64238 Len=0
18270	1287..	194.87.216.194	DESKTOP-GJQGBAT.local	ALLJOYN	55	CONNECT-initial byte
18271	1287..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	54	50639 → alljoyn-stm(9955) [ACK] Seq=69 Ack=4 Win=64237 Len=0
18272	1317..	194.87.216.194	DESKTOP-GJQGBAT.local	ALLJOYN	55	CONNECT-initial byte
18273	1317..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	54	50639 → alljoyn-stm(9955) [ACK] Seq=69 Ack=5 Win=64236 Len=0
18286	1347..	194.87.216.194	DESKTOP-GJQGBAT.local	ALLJOYN	55	CONNECT-initial byte
18287	1347..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	54	50639 → alljoyn-stm(9955) [ACK] Seq=69 Ack=6 Win=64235 Len=0
18290	1377..	194.87.216.194	DESKTOP-GJQGBAT.local	ALLJOYN	55	CONNECT-initial byte
18291	1377..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	54	50639 → alljoyn-stm(9955) [ACK] Seq=69 Ack=7 Win=64234 Len=0
18818	1401..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	66	50642 → alljoyn-stm(9955) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
18819	1401..	194.87.216.194	DESKTOP-GJQGBAT.local	TCP	58	alljoyn-stm(9955) → 50642 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
18820	1401..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	54	50642 → alljoyn-stm(9955) [ACK] Seq=1 Ack=1 Win=64240 Len=0
18821	1401..	DESKTOP-GJQGBAT.local	194.87.216.194	TCP	110	50642 → alljoyn-stm(9955) [PSH, ACK] Seq=1 Ack=1 Win=64240 Len=56

Рисунок 9 — Соединение с 194.87.216.194:9955

Анализ TCP Stream показывает, что внутренний узел 10.2.3.101 передаёт данные на оба внешних адреса (рисунок 10). С учётом времени соединений, их направления и связи с предшествующими загрузками данный трафик можно отнести к признакам возможного вывода данных из заражённой системы.

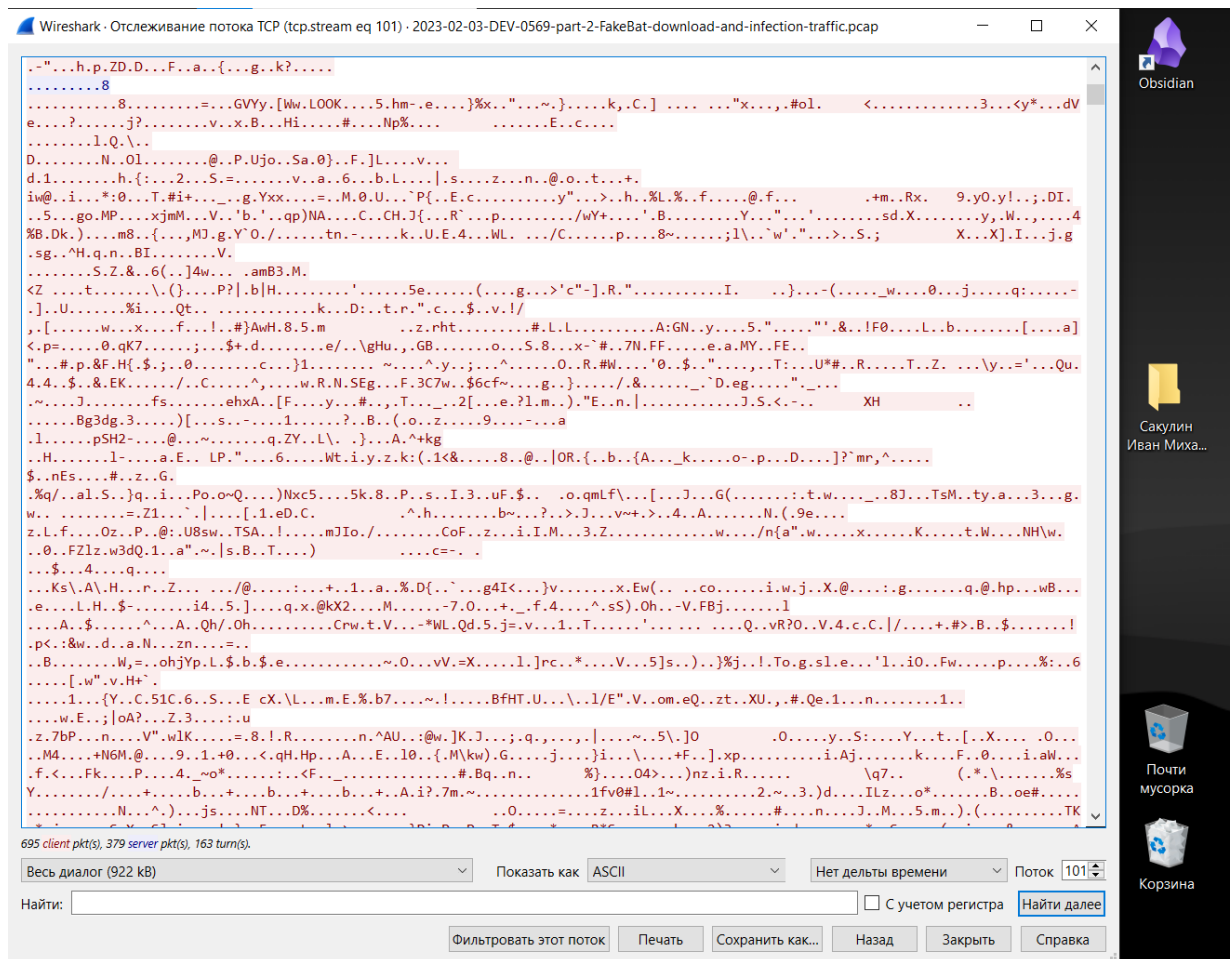
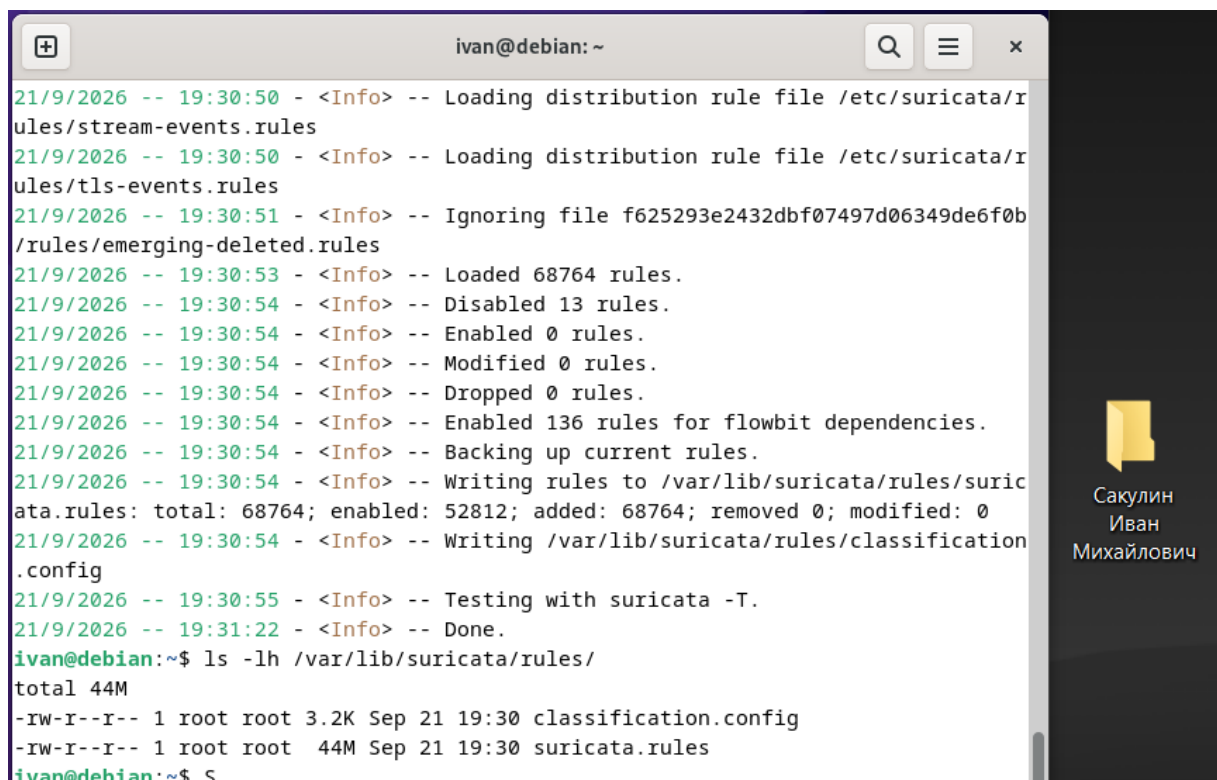


Рисунок 10 — TCP Stream при анализе подозрительного соединения

1.3 Автоматическое обнаружение в Suricata

1.3.1 Стандартные правила

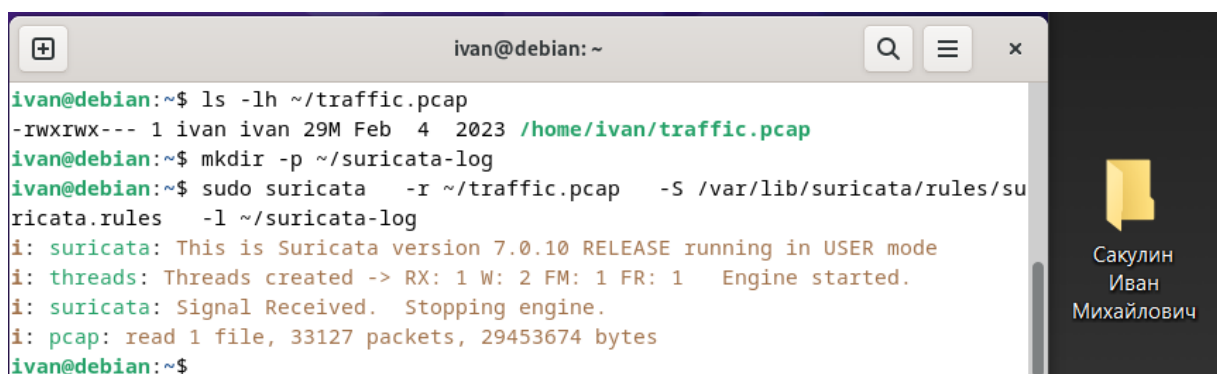
Была установлена Suricata (рисунок 11), после чего PCAP был обработан офлайн по стандартным правилам (рисунок 12).



A terminal window titled 'ivan@debian: ~' showing the installation and configuration of Suricata. The output includes loading distribution rule files, ignoring a specific file, loading 68764 rules, disabling 13 rules, enabling 0 rules, modifying 0 rules, dropping 0 rules, enabling 136 rules for flowbit dependencies, backing up current rules, writing rules to /var/lib/suricata/rules/suricata.rules, and writing /var/lib/suricata/rules/classification.config. The window also shows the result of a 'ls -lh' command on the rules directory.

```
ivan@debian: ~  
21/9/2026 -- 19:30:50 - <Info> -- Loading distribution rule file /etc/suricata/rules/stream-events.rules  
21/9/2026 -- 19:30:50 - <Info> -- Loading distribution rule file /etc/suricata/rules/tls-events.rules  
21/9/2026 -- 19:30:51 - <Info> -- Ignoring file f625293e2432dbf07497d06349de6f0b/rules/emerging-deleted.rules  
21/9/2026 -- 19:30:53 - <Info> -- Loaded 68764 rules.  
21/9/2026 -- 19:30:54 - <Info> -- Disabled 13 rules.  
21/9/2026 -- 19:30:54 - <Info> -- Enabled 0 rules.  
21/9/2026 -- 19:30:54 - <Info> -- Modified 0 rules.  
21/9/2026 -- 19:30:54 - <Info> -- Dropped 0 rules.  
21/9/2026 -- 19:30:54 - <Info> -- Enabled 136 rules for flowbit dependencies.  
21/9/2026 -- 19:30:54 - <Info> -- Backing up current rules.  
21/9/2026 -- 19:30:54 - <Info> -- Writing rules to /var/lib/suricata/rules/suricata.rules: total: 68764; enabled: 52812; added: 68764; removed 0; modified: 0  
21/9/2026 -- 19:30:54 - <Info> -- Writing /var/lib/suricata/rules/classification.config  
21/9/2026 -- 19:30:55 - <Info> -- Testing with suricata -T.  
21/9/2026 -- 19:31:22 - <Info> -- Done.  
ivan@debian:~$ ls -lh /var/lib/suricata/rules/  
total 44M  
-rw-r--r-- 1 root root 3.2K Sep 21 19:30 classification.config  
-rw-r--r-- 1 root root 44M Sep 21 19:30 suricata.rules  
ivan@debian:~$ S
```

Рисунок 11 — Установка и проверка версии Suricata



A terminal window titled 'ivan@debian: ~' showing the execution of Suricata for offline PCAP analysis. The user lists a PCAP file, creates a log directory, and runs 'sudo suricata -r ~/traffic.pcap -S /var/lib/suricata/rules/suricata.rules -l ~/suricata-log'. The output shows Suricata version 7.0.10 running in USER mode, threads created, signal received, and PCAP file read.

```
ivan@debian:~$ ls -lh ~/traffic.pcap  
-rwxrwx--- 1 ivan ivan 29M Feb 4 2023 /home/ivan/traffic.pcap  
ivan@debian:~$ mkdir -p ~/suricata-log  
ivan@debian:~$ sudo suricata -r ~/traffic.pcap -S /var/lib/suricata/rules/suricata.rules -l ~/suricata-log  
i: suricata: This is Suricata version 7.0.10 RELEASE running in USER mode  
i: threads: Threads created -> RX: 1 W: 2 FM: 1 FR: 1 Engine started.  
i: suricata: Signal Received. Stopping engine.  
i: pcap: read 1 file, 33127 packets, 29453674 bytes  
ivan@debian:~$
```

Рисунок 12 — Офлайн-анализ PCAP в Suricata

Анализ логов и сработавших правил (рисунок 13) показал наличие нескольких подозрительных событий.

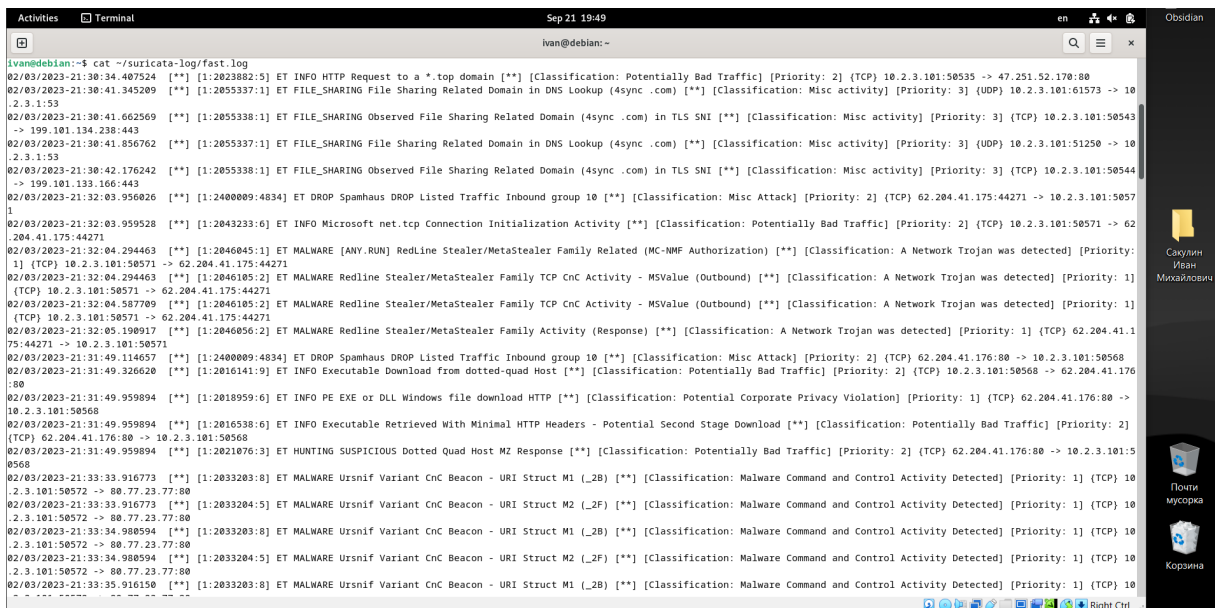


Рисунок 13 — Сработавшие правила Suricata при анализе PCAP

На этапе **доставки вредоносного ПО** Suricata обнаружила загрузку исполняемого файла с IP-адреса 62.204.41.176. Сработали правила ET INFO PE EXE or DLL Windows file download HTTP, ET INFO Executable Retrieved With Minimal HTTP Headers - Potential Second Stage Download и ET HUNTING SUSPICIOUS Dotted Quad Host MZ Response.

На этапе **управления и взаимодействия (C2)** было обнаружено соединение 10.2.3.101 -> 62.204.41.175:44271, которое Suricata определила как Redline Stealer/MetaStealer Family TCP CnC Activity. Также зафиксированы события Ursnif Variant CnC Beacon при соединениях с адресами 80.77.23.77, 80.77.25.109, 80.77.25.114 и 170.130.165.188.

На этапе **возможной эксфильтрации** Suricata зафиксировала события Ursnif Variant CnC Data Exfil, связанные с передачей данных от внутреннего хоста 10.2.3.101 к внешним адресам.

Таким образом, автоматический анализ Suricata подтвердил наличие признаков доставки вредоносного ПО, C2-взаимодействия и возможной эксфильтрации данных.

1.3.2 Собственное правило

Для обнаружения подозрительного соединения с внешним узлом было создано собственное правило. Его запись приведена на рисунке 14.

```
1 alert tcp 10.2.3.101 any -> 62.204.41.175 44271 (msg:"Possible C2  
  ↳ communication"; sid:1000001; rev:1;)
```

Рисунок 14 — Собственное правило Suricata

После запуска Suricata на PCAP правило сработало для соединения 10.2.3.101 -> 62.204.41.175:44271. Срабатывание собственного правила приведено на рисунке 15.



Рисунок 15 — Срабатывание собственного правила Suricata

Разбор правила:

- **alert** — действие: сформировать предупреждение при обнаружении совпадения;
- **tcp** — протокол анализируемого трафика;
- **10.2.3.101 any** — источник: внутренний хост 10.2.3.101, любой исходный порт;
- **62.204.41.175 44271** — назначение: внешний IP-адрес 62.204.41.175, порт 44271;
- **msg** — текст сообщения, выводимого при срабатывании правила;
- **sid** — уникальный идентификатор собственного правила;
- **rev** — номер версии правила.

Опция **content** в данном правиле не используется, поскольку правило основано на конкретных IP-адресе и порте, а не на поиске определённой строки в содержимом пакетов.

1.4 Сравнение

Результаты ручного и автоматического анализа сведены в таблицу 1.

Таблица 1 — Сравнение результатов ручного и автоматического анализа

Признак	Ручн.	Suricata	Комментарий
Загрузка putingod.exe с 62.204.41.176	Да	Да — ET INFO PE EXE or DLL Windows file download HTTP	Оба способа обнаружили доставку исполняемого файла
C2 62.204.41.175: 44271	Да	Да — Redline Stealer/MetaStealer Family TCP CnC Activity	Suricata дополнительно определила характер активности
C2-соединения с 80.77.23.77, 80.77.25.109, 80.77.25.114, 170.130.165.188	Да	Да — Ursnif Variant CnC Beacon	Автоматическое правило подтвердило подозрительную C2-активность
Возможная передача данных наружу	Да	Да — Ursnif Variant CnC Data Exfil	Suricata дала дополнительное подтверждение признаков эксфильтрации
Подозрительные ZIP/RAR-запросы	Да	Да — Dotted Quad Host ZIP Request / Dotted Quad Host RAR Request	Автоматический анализ позволил выявить дополнительные события

При ручном анализе основным преимуществом является возможность самостоятельно изучать контекст соединения: время, направление, объём трафика и содержимое TCP Stream. Это позволяет замечать подозрительные особенности, которые не обязательно представлены отдельным правилом IDS.

Suricata, в свою очередь, автоматически обнаруживает известные подозрительные шаблоны и классифицирует их по готовым сигнатурам. В данном

PCAP она обнаружила, в частности, загрузку EXE, RedLine/MetaStealer C2 и Ursnif C2/Data Exfil. Кроме того, автоматический анализ позволил выявить дополнительные события, в том числе запросы ZIP/RAR и обращения к другим подозрительным узлам.

Ложные срабатывания возникают, когда правило реагирует на легитимный трафик, похожий на подозрительный. Например, отдельные правила типа ET INFO или Potentially Bad Traffic сами по себе не всегда означают наличие атаки. Пропуски возможны, если для определённой активности нет подходящей сигнатуры или трафик изменён так, что правило не срабатывает. Поэтому чувствительность IDS необходимо настраивать с учётом особенностей сети.

Сила автоматической IDS заключается в скорости обработки большого количества трафика и автоматическом обнаружении известных признаков атак. Слабость состоит в зависимости от правил и возможных ложных срабатываниях или пропусках. Поэтому автоматическое обнаружение должно дополняться ручным анализом специалиста, который оценивает контекст событий.

ЗАКЛЮЧЕНИЕ

В ходе работы был проведён анализ сетевого трафика с использованием Wireshark и Suricata. Ручной анализ позволил подробно исследовать соединения, их направления, порты и TCP Stream, благодаря чему были обнаружены загрузка исполняемого файла, подозрительные C2-соединения и признаки возможной передачи данных наружу.

Автоматический анализ Suricata оказался удобен для быстрого обнаружения известных подозрительных шаблонов. В PCAP были автоматически выявлены доставка вредоносного ПО, C2-взаимодействие RedLine/MetaStealer и Ursnif, а также события, связанные с возможной экс-фильтрацией данных.

Наиболее отчётливо в трафике проявляются признаки доставки вредоносного ПО и C2-взаимодействия, поскольку для них присутствуют конкретные сетевые события и сигнатуры Suricata. При этом ручной анализ даёт возможность проверить контекст соединения и выявить подозрительную активность, для которой может не быть готовой сигнатуры.

В реальной инфраструктуре для защиты трафика целесообразно использовать комплексный подход: шифрование соединений, сегментацию сети, IDS/IPS, централизованный мониторинг и анализ сетевых событий. При этом автоматические средства обнаружения должны дополняться ручным анализом специалиста.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Malware-Traffic-Analysis.net. 2023-02-03 — Traffic analysis exercise [Электронный ресурс]. — URL: <https://www.malware-traffic-analysis.net/2023/02/03/index.html> (дата обращения: 21.09.2026).

ПРИЛОЖЕНИЕ А

Фильтры отображения в Wireshark

В приложении приведены примеры применения фильтров, использованных при ручном анализе трафика. В основном тексте отчёта ссылки на соответствующие изображения приведены при описании фильтров.

На рисунке А.1 приведён фильтр для выделения трафика внутреннего узла 10.2.3.101.

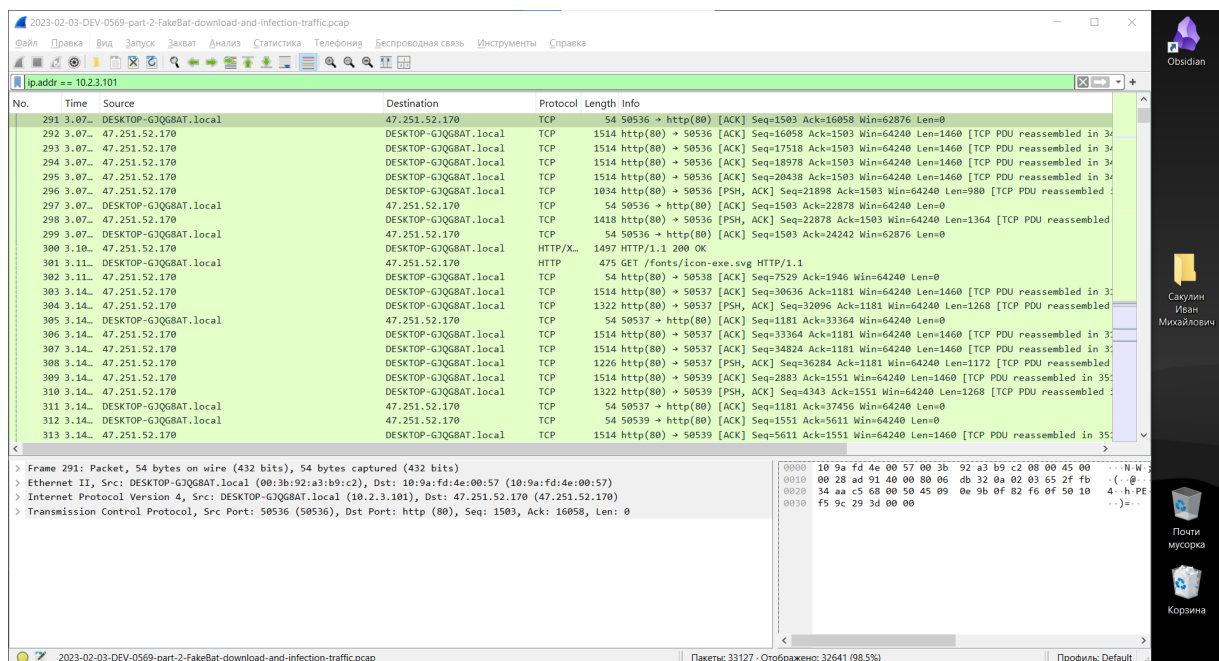


Рисунок А.1 — Фильтр `ip.addr == 10.2.3.101`

На рисунке А.2 приведён фильтр для просмотра веб-трафика.

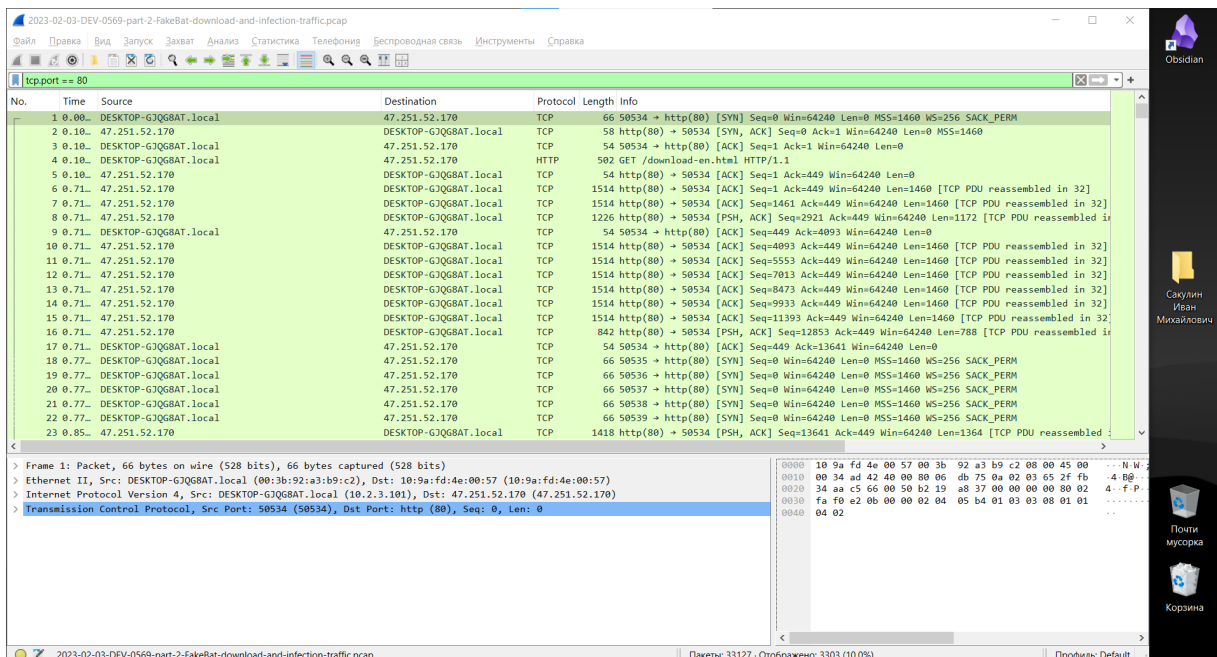


Рисунок А.2 — Фильтр tcp.port == 80 или http

На рисунке А.3 приведён фильтр для просмотра DNS-запросов.

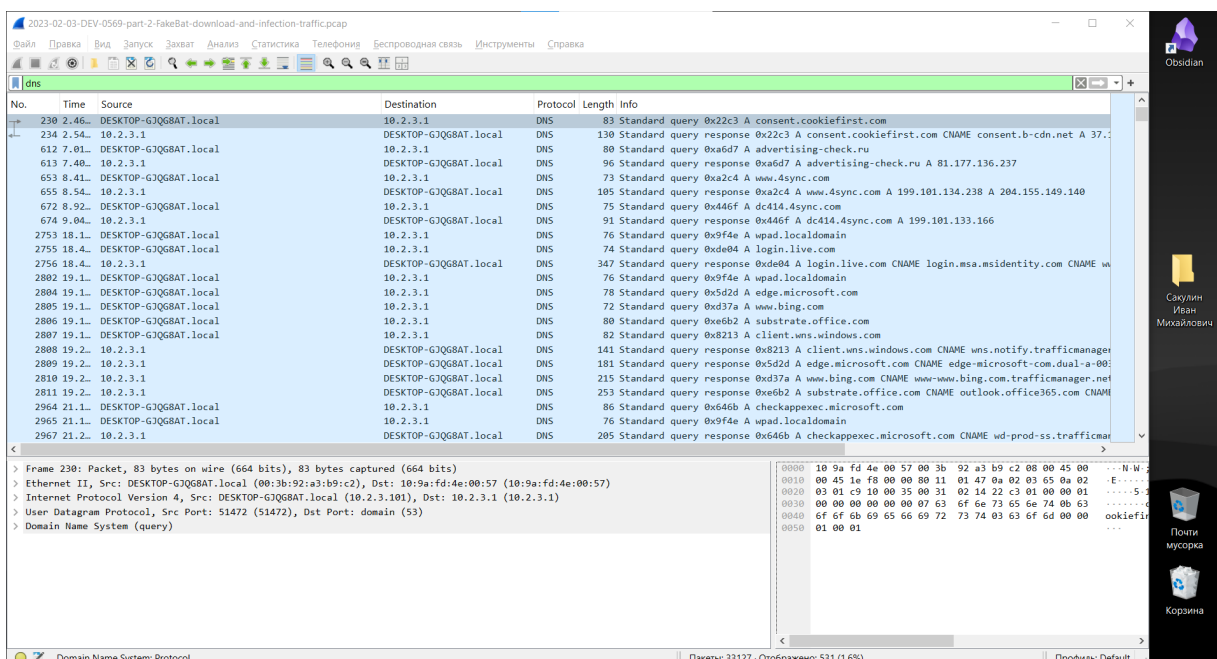


Рисунок А.3 — Фильтр dns

На рисунке А.4 приведён фильтр для выделения SYN-пакетов.

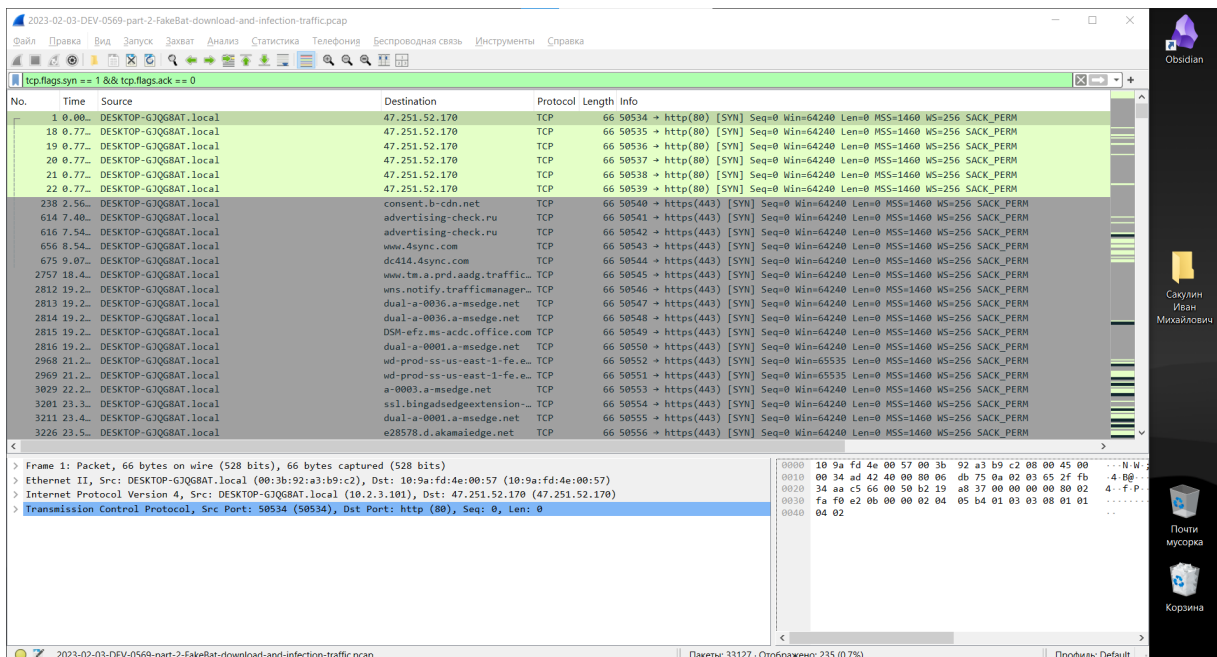


Рисунок А.4 — Фильтр tcp.flags.syn == 1 && tcp.flags.ack == 0

На рисунке А.5 приведён фильтр для отображения HTTP-запросов.

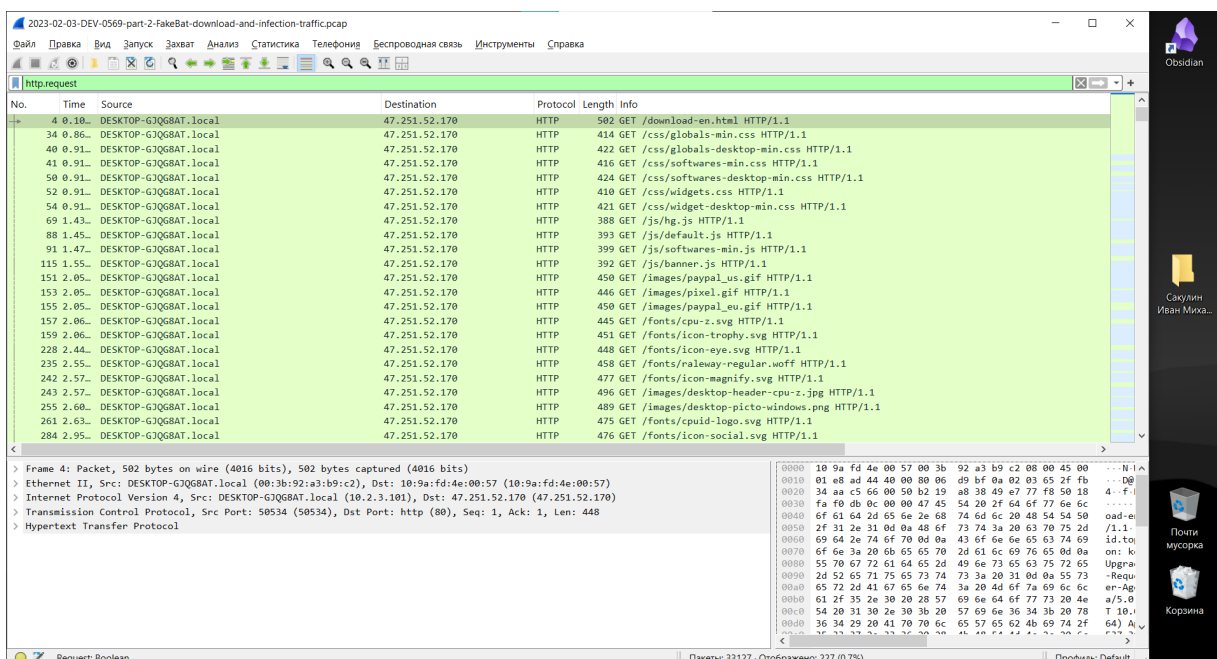


Рисунок А.5 — Фильтр http.request

На рисунке А.6 показано отсутствие результатов для FTP и Telnet.

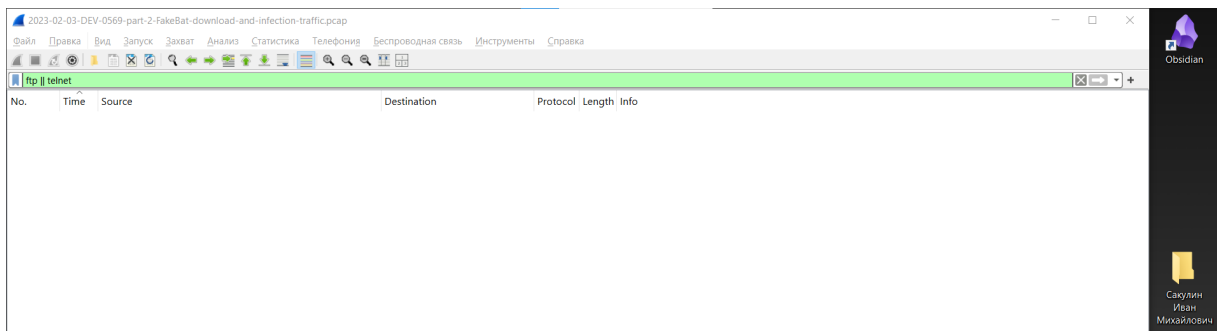


Рисунок А.6 — Фильтр ftp || telnet

На рисунке А.7 приведён фильтр для RST-пакетов.

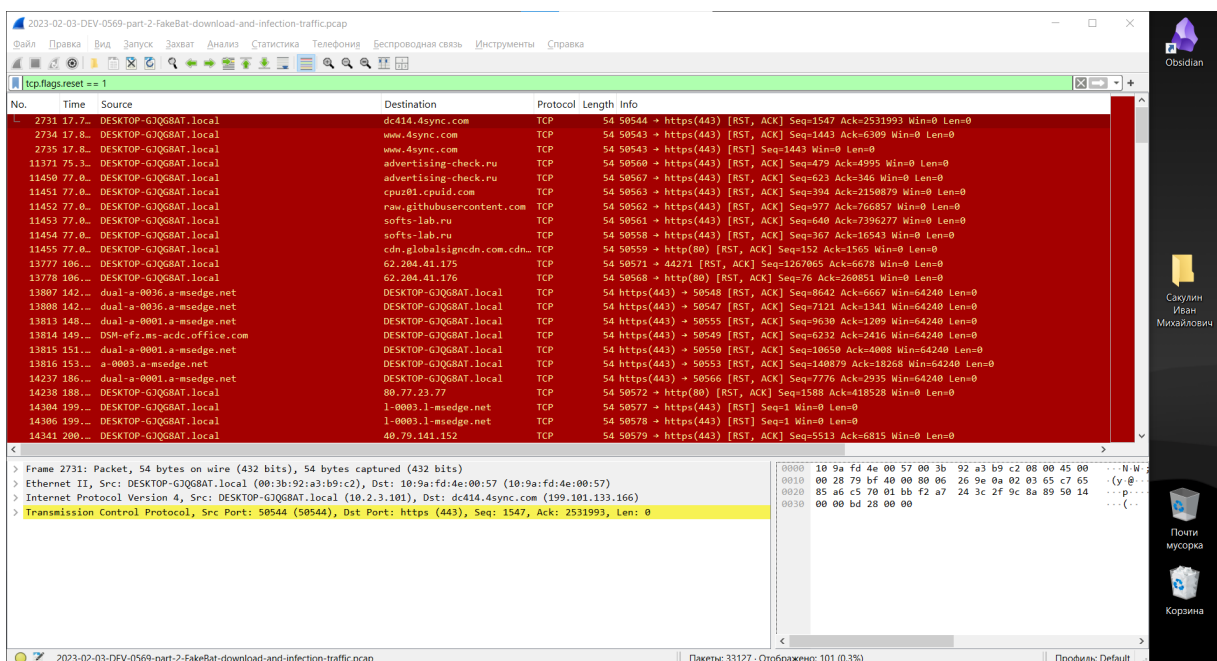


Рисунок А.7 — Фильтр tcp.flags.reset == 1

На рисунке А.8 приведён фильтр для HTTP POST-запросов.

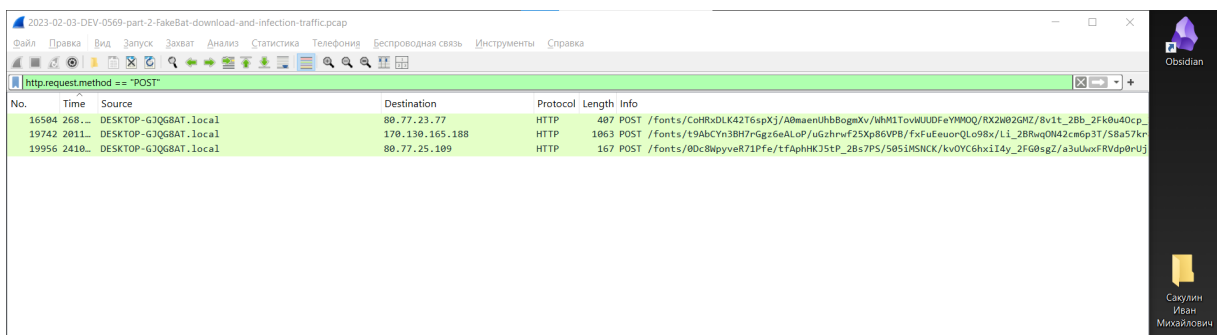


Рисунок А.8 — Фильтр http.request.method == "POST"